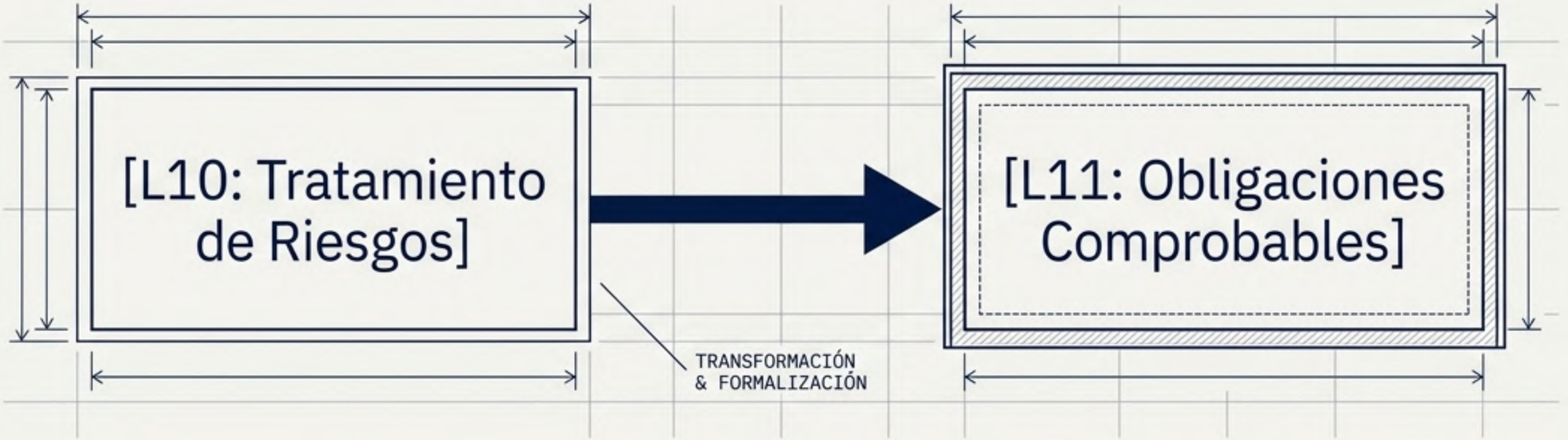
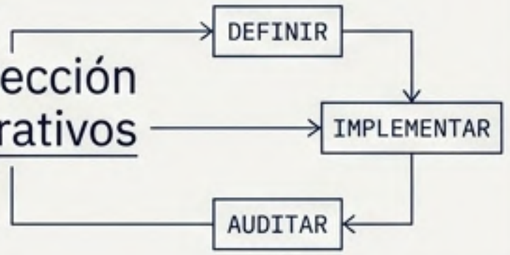
Lección 11: Política de seguridad, implementación y auditoría

Del tratamiento de riesgos a las obligaciones comprobables.



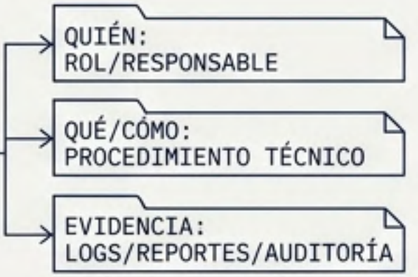
Propósito

Convertir decisiones de protección en requisitos técnicos y operativos medibles, implementarlos y auditar su eficacia.



Contexto

Un riesgo tratado requiere directrices claras: quién hace qué, cómo y qué evidencia lo demuestra.



Gemini Notebook

Technical Audit Blueprint



Riesgo Residual

Residual Esperado

La meta teórica tras diseñar el tratamiento.

Residual Actual

El nivel de riesgo real, calculado exclusivamente con evidencia de los controles operando.

Insight Clave

Firmar una política no reduce el riesgo real. La reducción solo ocurre cuando el control opera y se verifica.

Gemini Notebook

Documentos de Seguridad y su Estructura

Matriz Documental

Política	Obligación	¿Qué se exige y quién responde?
Estándar Técnico Interno	Valores permitidos	¿Qué parámetros exactos se aplican?
Procedimiento	Metodología	¿Cómo se ejecuta paso a paso?
Registro	Evidencia	¿Qué ocurrió en la realidad?

Separación de Roles



- Propietario de la política: mantiene el documento y coordina sus revisiones.
- Aprobador: autoridad competente que autoriza su vigencia.
- Ejecutor: implementa los controles.
- Verificador: revisa evidencia y resultados, preferentemente con independencia del ejecutor.

Estructura de la Política

Código	Requisitos
Versión	Excepciones
Objetivo	Incumplimientos
Alcance	Revisión
Roles	Vigencia/Aprobación

Gemini Notebook

De la Intención a la Obligación Verificable

Fórmula del Requisito

Responsable + debe + acción/objeto + alcance + plazo/frecuencia + evidencia

Antes / Después

Intención Vaga	Dato Faltante	Obligación Correcta
Se recomienda MFA.	Falta: obligatoriedad, plazo, evidencia.	Identidades debe exigir MFA (Autenticación Multifactor) a toda cuenta humana remota antes del alta, y conservar captura de configuración.
Equipos seguros.	Falta: parámetros, revisión.	Tecnología debe comprobar cifrado de disco y antivirus en el alta y en la revisión mensual (acta).
Permisos necesarios.	Falta: aprobador, fecha de fin.	El patrocinador debe aprobar servicios y ventana; Tecnología configura expiración.

Gemini Notebook

Políticas de Acceso Remoto y Relación con Riesgos

Matriz de Trazabilidad AR-Riesgos	
Reglas de Acceso Remoto (AR)	**Relación con Riesgos (R)**
AR-01: Cuentas humanas requieren asignación personal y MFA obligatorio. ⟶	(Contribuye a mitigar R-03 y mejora la trazabilidad de R-01, pero no reemplaza la baja de cuentas)
AR-03: Restricción estricta por orígenes, servicios y privilegios. ⟶	(Contribuye a mitigar la exposición relacionada con R-03)
AR-04: Terceros requieren patrocinador, autorización específica y caducidad. ⟶	(Controla accesos de terceros autorizados)
AR-06: Control riguroso de bajas e inactividad. ⟶	(Contribuye a mitigar R-01)

Distinción Fundamental (R-06)

Usuario Humano
Sujeto a MFA y expiración basada en contrato.

Cuenta Técnica (svc_backup)
Su relación con R-06: Tareas automáticas. No debe usarse como cuenta compartida. Exige control de secretos, privilegios mínimos y propietario identificado. No requieren necesariamente MFA interactivo humano, pero requieren autenticación adecuada para servicios.

Gemini Notebook

Hitos de Despliegue y Excepciones

1. Preparación

Aprobación formal, comunicación y capacitación de afectados.

2. Ejecución

Cambio planificado con procedimiento de reversión (rollback) listo.

3. Seguimiento

Verificación empírica de resultados mediante pruebas.

Gestión de Excepciones

Componentes Obligatorios:

- Autorización formal, alcance limitado, control compensatorio, fecha de vencimiento estricta, registro de cierre.

Regla Temporal Ficticia:

"Del 25/10 al 05/12, todo cambio en producción necesita excepción".

⚠ **Nota Crítica:**

Autorizar una excepción temporal de acceso no es equivalente a la aceptación formal del riesgo residual.

Gemini Notebook

Métricas de Control sin Ambigüedades

Elementos Esenciales: Toda métrica exige población, fuente de datos, fecha de corte, meta esperada y acción ante desvíos. (Prohibido inventar datos).

Tarjeta 1: Cobertura MFA

Fórmula:

$$\frac{(\text{Cuentas humanas remotas activas con MFA obligatorio}}{\text{Total de cuentas humanas remotas activas)}} \times 100$$

Ejemplo Simulado:

18/20 = 90 %

Nota:

El 90% no significa “90% de seguridad”. Identifica 2 cuentas sin cobertura obligatoria de MFA.

Fuente:

Inventario conciliado.

Tarjeta 2: Cuentas Inactivas

Fórmula:

Conteo de cuentas habilitadas cuyo último acceso supera el umbral establecido por la organización.

Fuente:

Estado de cuentas y registro de último acceso.

Gemini Notebook

Métodos de Evaluación (NIST SP 800-53A)

Metodologías Oficiales

1. Examinar	2. Entrevistar	3. Probar
Revisar documentos o configuración (ej. inspeccionar reglas UFW).	Preguntar a responsables (ej. consultar al patrocinador sobre bajas).	Ejecutar bajo condiciones y observar comportamiento (ej. conectar vía SSH).

Distinciones Críticas de Auditoría

Diseño vs. Operación		Población vs. Muestra		Esperado vs. Observado	
¿El control está bien formulado teóricamente?	¿Se ejecuta en la realidad consistentemente?	Todas las cuentas existentes	Un subconjunto analizado.	El criterio de éxito normativo	La realidad empírica detectada.

Estructura de la Ficha

Requisito → **Método** → **Muestra** → **Evidencia** → **Conclusión** → **Límite**

Fuente: NIST SP 800-53A.

Gemini Notebook

Plan de Auditoría: AR-01, AR-03, AR-04 y AR-06

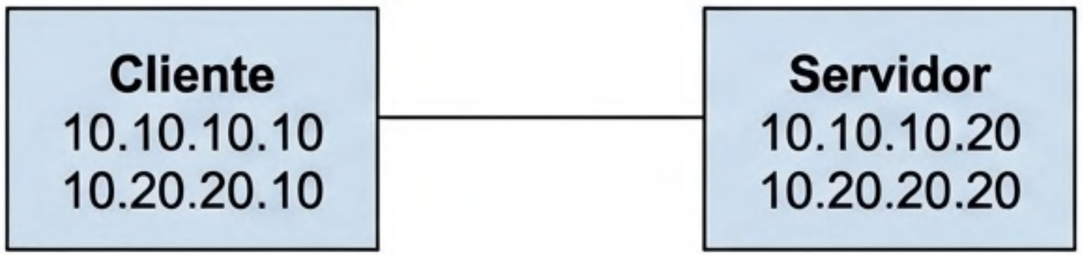
Obligación	Método	Muestra	Estado
AR-01	examinar inventario de cuentas y configuración MFA.	Cuentas humanas remotas.	«No ejecutado: diseño».
AR-03	examinar reglas UFW y probar conexiones permitidas y denegadas. (Nota: El laboratorio comprueba una restricción de origen hacia SSH, no toda la política AR-03 ni el caso empresarial).	Un servidor y dos orígenes IP.	Ejecución limitada a LAB11-SSH.
AR-04	entrevistar al patrocinador y examinar autorizaciones, contratos y expiraciones.	Cuentas de terceros.	«No ejecutado: diseño».
AR-06	examinar bajas de RR. HH. y registros de desactivación.	Desvinculaciones.	«No ejecutado: diseño».

Evaluación AR-04 (Terceros) - 3 Preguntas ABIERTAS al Patrocinador:

1. **Pregunta:** ¿Cómo confirma periódicamente que el tercero aún necesita acceso? → **Documento de Verificación:** Correo de validación o acta mensual.
2. **Pregunta:** ¿Qué proceso sigue si el contrato finaliza antes de la fecha programada? → **Documento de Verificación:** Ticket de baja anticipada.
3. **Pregunta:** ¿Cómo determina los servicios exactos requeridos por el técnico externo? → **Documento de Verificación:** Matriz de roles o formulario de solicitud aprobado.

Gemini Notebook

Topología
(lab_seguridad - Red Interna VirtualBox)



Nota: Ambas subredes IP comparten una red interna VirtualBox; no hay dos VLAN independientes.

Diagnóstico Inicial

Cliente, usuario docente:

```
ip -br addr
ip route
ping -c 2 10.10.10.20
ping -c 2 10.20.20.20
```

Servidor, consola local:

```
sudo ufw status verbose
sudo ufw status numbered
```

Prueba inicial desde el cliente:

```
ssh -o ConnectTimeout=8 admin01@10.20.20.20
```

Alcanzar la petición de contraseña demuestra acceso al servicio SSH desde el origen que después será restringido, pero no demuestra autenticación exitosa.

Falla Detectada:	Regla 22/tcp ALLOW IN Anywhere. Permite alcanzar el servicio SSH desde cualquier origen, sin garantizar autenticación ni autorización.
A Conservar:	El permiso 443/tcp no debe alterarse.

Gemini Notebook

Comandos del **laboratorio**

Servidor - consola local, usuario admin01

1. `sudo ufw allow from 10.10.10.0/24 to any port 22 proto tcp`
2. `sudo ufw delete allow 22/tcp`
3. `sudo ufw status numbered`
4. `sudo ufw status verbose`

Explicación Lógica:

Se agrega primero el permiso específico para 10.10.10.0/24 y después se elimina el permiso general de SSH

Agregar el permiso específico no restringe el acceso mientras continúe existiendo el permiso general.

Se valida “entrada denegada por defecto” (paso 4).

Se comprueba la conservación de 443/tcp y la eliminación de reglas amplias IPv6.

Gemini Notebook

Comandos y resultados esperados

Cliente - usuario docente

Permitido: `ssh -o ConnectTimeout=8 admin01@10.10.10.20`
(Se espera iniciar sesión como admin01 y salir con exit.)

Denegado: `ssh -o ConnectTimeout=8 admin01@10.20.20.20` (Se espera timeout. Este resultado debe contrastarse con un registro UFW BLOCK en el servidor que coincida en hora, SRC, DST y DPT=22)

Comandos y resultados esperados

Servidor (Log)

Comando:

```
sudo journalctl -k --since -20min | grep 'UFW BLOCK' | tail -5
```

Lectura de Trazabilidad:
Buscar coincidencia de hora, SRC=10.20.20.10, DST=10.20.20.20, y DPT=22.

Aclaraciones Técnicas Críticas
- Obtener una petición de contraseña ≠ autenticación exitosa (solo se alcanzó el servicio).
- Obtener un timeout ≠ prueba concluyente de bloqueo por firewall. Sin registro en log, es una "causa no confirmada".

Gemini Notebook

Estructuración de Evidencia y Hallazgos

Mapeo de Evidencias		
E1: Entorno inicial	**E2:** UFW inicial	**E3:** Acceso inicial amplio.
E4: Reglas finales	**E5:** Acceso permitido	**E6:** Denegado + Log UFW BLOCK.



Límites Rigurosos de la Prueba
- Corregir **LAB11-SSH** no cierra el hallazgo **H-01** del caso PACÍFICO RETAIL. - Esta prueba no demuestra configuración ni funcionamiento de **MFA**. - Conservar la regla **443/tcp** no demuestra que exista un sitio **HTTPS** operando, solo que el puerto está abierto.

Gemini Notebook

Requisitos en Fase de Diseño de Software

Aplicado al “Portal de Pedidos”

D-01: Modelado de Amenazas

(NIST SSDF 1.1 PW.1.1)

Adaptación a Regla: El Arquitecto de Software debe documentar el modelo de amenazas del portal antes de aprobar el diseño final, conservando el acta de revisión como evidencia formal.

D-02: Autorización por Función/Dato

(OWASP ASVS 5.0.0 V8.1.1)

Adaptación a Regla: El Equipo de Arquitectura debe aprobar una matriz de permisos por función y tipo de dato (ej. el cliente solo puede ver sus propios pedidos) previo al desarrollo, conservando la matriz como evidencia.

Fuentes: NIST SP 800-218 (SSDF), OWASP ASVS 5.0.0.

Gemini Notebook

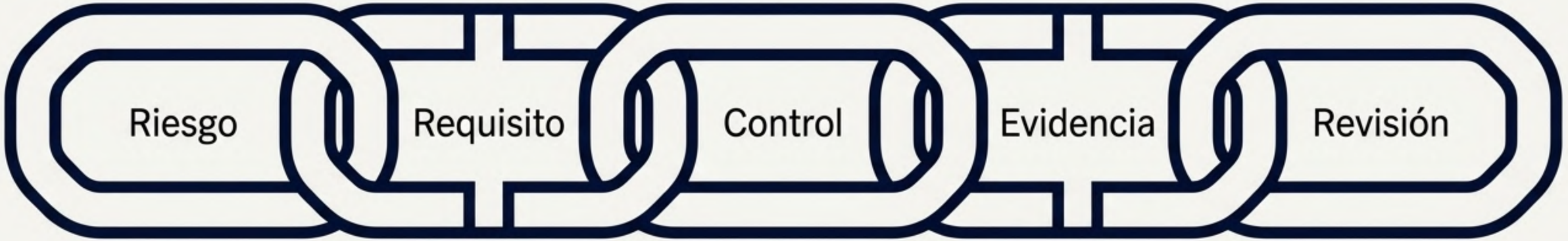
Requisitos en Fase de Construcción y Trazabilidad

C-01: Consultas Parametrizadas (OWASP ASVS 5.0.0 V1.2.4)

Obligación: Los Desarrolladores deben usar consultas protegidas/parametrizadas u ORM en el portal para evitar inyecciones, verificado mediante prueba de código.

C-02: Revisión de Código y Seguimiento (NIST SSDF 1.1 PW.7.2)

Obligación: El equipo de QA debe revisar el código contra el estándar de seguridad interno y registrar el seguimiento de resolución de problemas antes del pase a producción (ticket).



(La seguridad no es un estado, es una obligación verificada de manera continua).

Fuentes: NIST SP 800-218 (SSDF), OWASP ASVS 5.0.0.

Gemini Notebook